updates, standardizes checks across services, and enables consistent logging and auditing—without altering application code. However, API gateways operate at the perimeter of the system, which limits their ability to make deeply contextual decisions that depend on the internal application state.

Finally, deploying the PEP in a sidecar container, as seen in service mesh architectures, enables policies to be enforced at the infrastructure level for all inbound and outbound service traffic. This pattern facilitates microservice-to-microservice authorization and is ideal for zero trust architectures; however, it introduces complexity regarding proxy management, policy synchronization, and ensures that fresh context is available locally.

No single option is best—each has its place. Many organizations use a combination of these models, incorporating coarse-grained checks at the gateway with more contextual logic in the app or mesh. The key is to understand your system's trust boundaries, performance requirements, and policy lifecycle needs.

4.5.2 Centralized PDPs

The Policy Decision Point (PDP) is the component responsible for evaluating access requests against a defined set of policies. At ACME Corp, several internal applications—including ACMEProject, ACMEHR, and ACMEFinance—use a centralized PDP to manage authorization decisions. As illustrated in figure 4.6, each application has its own Policy Enforcement Point (PEP), which forwards requests to the shared PDP.